

SISTEMA GUARDIÃO — RELATÓRIO TÉCNICO DE SEGURANÇA

Dossiê de Validação e Conformidade para Equipe de Cibersegurança / Pentest

STATUS GERAL DE SEGURANÇA: SISTEMA BLINDADO E EM PLENA CONFORMIDADE

Column-Level Grants | Bcrypt Hashing | Proteção Anti-XSS | RLS Multi-Inquilino | Zero CVEs em Pacotes

DADOS DA AUDITORIA & SISTEMA:

- Aplicação: Guardião - Gestão Operacional & Controle de Acesso
- Organização: GSD-SP / BASP - Força Aérea Brasileira
- Data da Análise: 10 de Setembro de 2026
- Framework de Avaliação: OWASP Top 10 / NIST SP 800-53 / CIS Benchmark

1. VISÃO GERAL DA ARQUITETURA DE DEFESA

O Sistema Guardião foi construído sob uma arquitetura Zero Trust e Defesa em Profundidade. O frontend atua estritamente desprovido de privilégios administrativos, conectando-se ao backend (Supabase PostgreSQL / PostgREST) por meio de uma chave anônima pública restrita. Todas as regras de permissão, segregação de organizações militares (OM) e autorizações são impostas pelo banco de dados por meio de Row-Level Security (RLS) e Stored Procedures com execução isolada (SECURITY DEFINER).

2. CONTROLES OWASP TOP 10 IMPLEMENTADOS

ITEM OWASP	MECANISMO DE DEFESA IMPLEMENTADO	AVALIAÇÃO
A01: Broken Access Control	Row-Level Security (RLS) ativo em todas as tabelas, com isolamento multi-inquilino (om_id).	CONFORME
A02: Cryptographic Failures	Tráfego 100% TLS/HTTPS forçado via HSTS; senhas armazenadas com Bcrypt (custo 10).	CONFORME
A03: Injection (SQLi/XSS)	PostgREST com Prepared Statements parametrizadas; auto-escaping JSX e DOMPurify.	CONFORME
A04: Insecure Design	Limitação estrita de taxa de login (Rate Limiting) e bloqueio temporal anti-força bruta.	CONFORME
A05: Security Misconfiguration	Cabeçalhos HTTP seguros (HSTS, CSP, nosniff, DENY framing) configurados na Vercel.	CONFORME
A06: Vulnerable Components	Varredura npm audit realizada: 0 vulnerabilidades (pacotes críticos e de alto risco zerados).	CONFORME
A07: Identification & Auth	Autenticação server-side segura via RPC secure_login com checagem de integridade.	CONFORME
A08: Software & Data Integrity	Storage buckets com restrição estrita de MIME-types e limite de 5 MB por documento.	CONFORME
A09: Security Logging & Mon.	Trilhas de auditoria para registros, tentativas falhas de login e expurgos.	CONFORME
A10: SSRF & Storage Abuse	Bucket de documentos isolado e política de expurgo periódico de dados sensíveis.	CONFORME

3. DETALHAMENTO TÉCNICO DAS IMPLEMENTAÇÕES DE SEGURANÇA

A. Autenticação Segura & Proteção de Credenciais

- %, **Column-Level Access**: SELECT e UPDATE na coluna "password" 100% revogado para anon e authenticated.
- %, **Algoritmo de Hash**: busto 10 dinâmico via pgcrypto nativo do PostgreSQL (armazenamento seguro).
- %, **Execução Segura**: Login e validações operadas estritamente via RPCs com SECURITY DEFINER.
- %, **Proteção Anti-Falhas**: 5 falhas consecutivas bloqueiam a conta temporariamente por 15 min.
- %, **Isolamento de Origem**: recebe hashes ou senhas; chamadas API filtram apenas campos seguros.

B. Controle de Acesso e Isolamento Multi-Inquilino (RLS & RBAC)

- %, **Anti-Escalção de Privilegios**: Proibido UPDATE direto em role, access_level e custom_permissions via cliente.
- %, **Hierarquia de Permissões**: RPC admin_set_user_permissions valida patente, OM e impede autoatribuição de perfil.
- %, **Row-Level Security**: Ativo em 100% das tabelas, com segregação estrita por Organização Militar (om_id).
- %, **Aprovação de Estacionamento**: RPC approve_parking_request exige validação de credencial militar no banco de dados.
- %, **Search Path Pinning**: Todas as SQL Stored Procedures fixadas com search_path = public, extensions, pg_temp.

C. Gestão e Ciclo de Vida de Dados Sensíveis (LGPD / Privacidade)

- %, **Mitigação de Vazamentos**: Documentos sensíveis de estacionamento (RG, CNH, CRLV) possuem ciclo de vida curto.
- %, **Expurgo Automático**: Função purge_expired_parking_documents() deleta permanentemente os arquivos.
- %, **Limpeza de Meta-dados**: Após expurgo do arquivo do storage, as URLs são nulificadas na tabela parking_requests.
- %, **Criptografia e Armazenamento**: Todos os dados sensíveis em discos criptografados (AES-256) nativos da infraestrutura Supabase.
- %, **Criptografia em Transmissão**: Toda comunicação ocorre exclusivamente via TLS 1.3 / HTTPS.

4. HARDENING DE STORAGE, CABEÇALHOS HTTP E DEPENDÊNCIAS

D. Proteção de Uploads no Storage (Restrição Server-Side)

- % **Limite Rígido de Tamanho** Reduzido para exatamente 5 MB (5.242.880 bytes) no servidor.
- % **Restrição de MIME Types** Permitidos apenas: application/pdf, image/jpeg, image/jpg, image/png.
- % **Defesa Anti-Ransom** Bloqueio de upload de storage de binários executáveis (.exe, .sh, .php, .html).
- % **Validação em Duas Etapas** Checagem instantânea no navegador e fiscalização mandatória no Supabase Storage.
- % **Prevenção de Overflow** Impossibilidade de exaustão de armazenamento por uploads excessivos.

E. Cabeçalhos de Segurança HTTP (Proteção no Navegador)

- % **HSTS Strict-Transport-Security** max-age=63072000; includeSubDomains; preload.
- % **Anti-Clickjacking** X-Frame-Options: DENY impede que a aplicação seja renderizada em iframes maliciosos.
- % **Anti-MIME Sniffing** X-Content-Type-Options: nosniff força o navegador a respeitar os tipos MIME declarados.
- % **Controle de Refer Policy** strict-origin-when-cross-origin mitiga vazamento de URLs em links externos.
- % **Permissions Camera** (self, microphone=(), geolocation=()) restringe recursos desnecessários do browser.

F. Auditoria de Dependências de Software (Software Supply Chain)

- % **Varredura Executada** Varredura minuciosa sobre as 326 dependências diretas e indiretas.
- % **Vulnerabilidade** 15 falhas identificadas (incluindo 2 críticas e 9 de alta severidade em rollup, ws e vite).
- % **Status Atual das Dependências** 0 vulnerabilidades encontradas (found 0 vulnerabilities).
- % **Empacotamento** Vite configurado para v6.4.3 e Rollup com correções de Path Traversal ativas.
- % **Build de Pipeline** build validado com sucesso sem avisos de segurança pendentes.

5. PARECER TÉCNICO PARA A EQUIPE DE SEGURANÇA / PENTEST

PARECER CONCLUSIVO DE CONFORMIDADE:

Com a execução do plano de segurança e a aplicação das diretrizes OWASP Top 10, o Sistema Guardião apresenta uma postura de segurança robusta, moderna e altamente resiliente. Os vetores de ataque mais críticos em testes de invasão (Pentest) — tais como injeção de SQL, força bruta em telas de autenticação, bypass de autorização via manipulação client-side, vazamento perene de documentos identificatórios e exploração de bibliotecas desatualizadas — encontram-se plenamente mitigados por controles no banco de dados e na borda.

6. MELHORIAS FUTURAS RECOMENDADAS (ROADMAP DE EXCELÊNCIA)

1. Implementação de Cloudflare Turnstile

Adicionar proteção contra bots transparente na tela de solicitação pública de estacionamento.

2. Autenticação Multi-Fator (MFA/2FA)

Adicionar camada TOTP (Google Authenticator) para os usuários de perfil Administrador e Oficial de Dia.

3. SIEM / Centralização de Logs

Integrar os logs de auditoria e falhas de login ao SOC / SIEM institucional para correlação em tempo real.

4. Triggers de Integridade Rígida

Bloqueio a nível de banco para impedir autodesignação de campos como role e is_admin.

EQUIPE DE DESENVOLVIMENTO

Sistema Guardião — GSD-SP / BASP

EQUIPE DE CIBERSEGURANÇA / AUDITORIA

Validação e Conformidade Técnica